

Identity Management and Access Control Policy

FortisAid Health Technologies

Policy Number: FTAID-POL-003

Version 1.0 | Effective: 18 Feb 2026

Document Control Page

Field	Details
Policy Title	Identity Management and Access Control Policy
Policy Number	FTAID- IAM-POL-003
Author	Daniel Azeez
Policy Owner	Chief Information Security Officer
Reviewer	Information Security Manager
Approver	Chief Executive Officer (CEO), FortisAid
Version	1.0
Effective Date	18 February 2026

Current Review Date	18 February 2026
Next Review Date	18 February 2027
ISO 27002:2022 Domain	Organizational Controls
ISO 27002:2022 Sub-domain	Access Control, Identity Management
ISO 27002:2022 Control Reference(s)	5.15, 5.16
Related Policies	Classification of Information Policy Access Rights Policy Privileged Access Rights Policy
Approval Status	Approved

Approval Evidence

Approver: Chief Executive Office

X

Chief Executive Officer

Date: 18 Feb 2026

Purpose and Scope

Purpose:

This policy ensures that FortisAid controls access to its information systems, applications, and physical assets by appropriately managing identity and access rights to safeguard the confidentiality, integrity, and availability of sensitive healthcare data.

Scope:

This policy applies to all employees, contractors, clinicians, and vendors who require access to FortisAid's IT systems, applications, and data, including Electronic Health Records (EHR), patient health information (PHI), and cloud systems.

FortisAid Context:

Given FortisAid's commitment to providing safe and high-quality healthcare services, this policy covers how patient data, including sensitive health records, is accessed and managed securely across FortisAid's internal systems, including EHR systems, cloud storage, and remote access to clinical data.

ISO 27002:2022 Alignment

ISO Domain	ISO Sub-domain	Control Number	How this policy addresses it
Organizational Controls	Access Control	5.15	Defines the controls for managing user access to FortisAid's systems and applications to prevent unauthorized access.
Organizational Controls	Identity Management	5.16	Ensures the full lifecycle of identity management, from creation to removal or

			modification, and aligns with access controls.
--	--	--	--

Threats and Key Risks (Healthcare Context)

Threats:

- Unauthorized access to sensitive healthcare data.
- Insider threats leading to the compromise of patient data.
- Inadequate access control over remote systems leading to breaches.

Key Risks to FortisAid:

- Risk 1: Potential breach of PHI leading to non-compliance with HIPAA and other regulations, as well as reputational damage.
- Risk 2: Increased likelihood of data loss or compromise due to improper access rights.
- Risk 3: Operational disruptions caused by unauthorized changes or access to clinical applications and systems.

Policy Statements / Requirements

Access Control Rules

- Access to FortisAid's systems and assets shall be restricted in accordance with the **Need-to-Know** and **Need-to-Use** principles.
- Access to healthcare data will be role-based (RBAC), ensuring that individuals are granted the minimum level of access necessary to perform their job functions.
- Access control rules shall be formally defined, approved, and periodically reviewed to ensure alignment with FortisAid's information classification, regulatory obligations, and patient safety requirements.

Identity Management

- Each user identity must be unique and associated with a specific individual or entity.
- Identities must be disabled or removed when no longer required (e.g., upon termination or role change).

- Third-party identities (e.g., contractors) must be verified for appropriate trust level before granting access.

Compliance and Enforcement

Monitoring Activities:

- Frequency: Quarterly reviews of access logs.
- Responsible Role: IAM Specialist and IT Security Team.
- Evidence Stored: Logs and reports are maintained for auditing purposes.

Non-Compliance:

Violations may result in disciplinary action, up to and including termination, and may be reported to regulatory authorities where required.

Training and Awareness

- Mandatory completion of policy-specific training within 30 days of joining.
- Annual refresher training for all staff.
- Role-specific training for privileged roles and clinical staff.

Review and Revision

- This policy will be reviewed annually or following significant incidents or regulatory changes.
- Next scheduled review: **18 February 2027**.